

Real EMIL Claims Service — What Else To Test

This guide captures production-grade test coverage areas beyond a take-home mock setup.

1. Authentication

- Missing token -> 401 Unauthorized
- Expired token -> 401 Unauthorized
- Invalid signature/issuer/audience -> 401 Unauthorized
- Revoked token/session handling
- Service-to-service auth behavior (for internal calls)

2. Authorization and Permissions

- Role-based matrix by endpoint and action (viewer/handler/approver/admin)
- Field-level authorization (for example, only approvers can set payout fields)
- Transition permissions (who can move claim from one state to another)
- Deny-by-default behavior for unknown roles/scopes
- Tenant isolation: tenant A cannot read/update tenant B claims

3. Race Conditions and Concurrency

- Two concurrent updates to the same claim (conflicting transitions)
- Double-approval and double-payment prevention
- Concurrent read/write consistency guarantees
- Optimistic locking/version checks (ETag/version column) behavior
- Last-write-wins behavior if that is the selected strategy

4. Idempotency

- POST /claims replay with same idempotency key returns same result
- Same idempotency key with different payload returns conflict (409)
- Safe retry behavior after timeout/network drop
- Idempotency key TTL/expiry behavior
- Duplicate processing prevention across retries and restarts

5. State Machine Integrity

- Full valid transition coverage
- Full invalid transition coverage
- Terminal state enforcement (PAID, REJECTED, etc.)
- Re-open flows (if business allows)
- Permission-aware transitions (state + role)

6. Data Validation and Integrity

- Cross-service reference checks (policy must exist and be active)
- Date integrity rules (future dates, timezone boundaries)
- Monetary precision and rounding (decimal safety, currency rules)
- Required/optional field behavior by status
- Duplicate claim detection rules

7. Resilience and Failure Handling

- Dependency failure behavior (policy/payout/fraud services unavailable)
- Retry/backoff/circuit-breaker behavior
- Transaction boundaries and rollback on partial failures
- Correct 5xx mapping without leaking internals
- Graceful degradation paths where applicable

8. Security

- IDOR/BOLA checks for claim IDs and list filters
- Injection resilience (query/body/header abuse)
- Sensitive data exposure checks (errors, logs, traces)
- Rate limiting/abuse controls
- Secure audit trail integrity and tamper resistance

9. Observability and Auditability

- Correlation IDs propagated through all services
- Audit event completeness for every critical action
- Structured logs with actionable error codes
- Metrics for success/error/latency by endpoint
- Alerting thresholds for auth failures, error spikes, and latency regressions

10. Performance and Scale

- List/filter endpoints under high data volume
- P95/P99 latency under expected and peak load
- Throughput limits and saturation behavior
- Soak tests for long-running stability
- Back-pressure behavior under burst traffic

11. Contract and Backward Compatibility

- OpenAPI contract validation in CI for each release
- Breaking-change detection and consumer impact checks
- Versioning strategy tests (v1/v2 coexistence if applicable)
- Error schema consistency across all endpoints

12. Environment and Release Safety

- Prod-like environment parity checks
- Migration safety (forward/backward compatibility)
- Feature-flag behavior validation
- Rollout and rollback validation
- Smoke tests post-deployment

Suggested Test Layers

- Unit tests for pure business rules and transition logic
- Contract tests for API schema and error shape
- Integration tests across dependencies
- End-to-end tests for business-critical user journeys
- Non-functional tests (security, performance, resilience)